



Weekly IT Security Brief (Official-source-first) | 2026-09-06 06:00

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 5 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-85046(2026-09-18), CVE-2026-59822(2026-09-16), CVE-2026-48710(2026-09-16). Prioritize internet-facing and privileged systems first.
- Threat trend #1: How to secure edge AI in customer-owned environments. As AI moves into customer-owned environments, organizations need new ways to verify the systems, software, and AI assets they trust before releasing sensitive data, credentials, and models...
- Threat trend #2: ASCII smuggling crosses over from AI prompt injection to phishing evasion. The post ASCII smuggling crosses over from AI prompt injection to phishing evasion appeared first on Microsoft Security Blog . Recommendation: prioritize vulnerable...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-85046

CVE Title	CVE-2026-85046 google/chrome Unknown Type
CVE Description	Type confusion in V8 in Google Chrome prior to 152.0.7977.82 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: High)
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	google/chrome
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-18
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-85046

CVE-2026-59822

CVE Title	CVE-2026-59822 litellm/litellm Unknown Type
CVE Description	LiteLLM is a proxy server (AI Gateway) to call LLM APIs in OpenAI (or native) format. Prior to 1.84.0, LiteLLM's MCP Streamable HTTP endpoint allowed an unauthenticated attacker to use a fabricated Authorization header to trigger an OAuth2 passthrough fallback path that replaced failed LiteLLM key validation with an empty UserAPIKeyAuth() object, allowing requests to reach MCP tooling without a valid LiteLLM ke...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	litellm/litellm
Risk Score	8.2 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-16
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-59822

CVE-2026-48710

CVE Title	CVE-2026-48710 encode/starlette Unknown Type
CVE Description	Starlette is a lightweight ASGI framework/toolkit. Prior to version 1.0.1, the HTTP `Host` request header was not validated before being used to reconstruct `request.url`. Because the routing algorithm relies on the raw HTTP path while `request.url` is rebuilt from the `Host` header, a malformed header could make `request.url.path` differ from the path that was actually requested. Middleware and endpoints that apply...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	encode/starlette, redhat/ai_inference_server, redhat/ansible_automation_platform, redhat/migration_toolkit_for_applications, redhat/openshift_ai
Risk Score	6.5 (MEDIUM)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-16
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-48710

CVE-2026-49869

CVE Title	CVE-2026-49869 kestra/kestra Remote Code Execution
CVE Description	Kestra is an open-source, event-driven orchestration platform. Prior to 1.0.45 and 1.3.21, AuthenticationFilter in Kestra OSS uses request.getPath().endsWith("/configs") to whitelist the public configuration endpoint from Basic Auth. Because the check is a suffix match rather than an exact path match, any API path whose last segment is configs bypasses authentication entirely. An unauthenticated remote att...
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	kestra/kestra
Risk Score	10.0 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-05
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-49869

CVE-2026-82329

CVE Title	CVE-2026-82329 jfrog/artifactory Unknown Type
CVE Description	JFrog Artifactory contains an authentication weakness that, under default configuration, may allow an unauthenticated attacker with network access to obtain administrative privileges.
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	jfrog/artifactory
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-09-05
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-82329



Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-82422

CVE Title	CVE-2026-82422 待核實 SQL Injection
CVE Description	A security flaw has been discovered in itsourcecode Sales and Inventory System 1.0. Impacted is an unknown function of the file /pages/emp_del.php. The manipulation of the argument ID results in sql injection. The attack may be launched remotely. The exploit has been released to the public and may be used for attacks.
Affected Products	待核實
Risk Score	6.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-82422

CVE-2026-82423

CVE Title	CVE-2026-82423 待核實 Unknown Type
CVE Description	A vulnerability has been found in macrozheng mall up to 1.0.3. The affected element is an unknown function of the file /order/paySuccess of the component Payment Status Endpoint. The manipulation of the argument orderId leads to enforcement of behavioral workflow. The attack is possible to be carried out remotely. The vendor deleted the GitHub issue for this vulnerability without any explanation.
Affected Products	待核實
Risk Score	5.4 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-82423

CVE-2026-82424

CVE Title	CVE-2026-82424 待核實 SQL Injection
CVE Description	A weakness has been identified in PHPGurukul Student Information System 1.0. Affected by this vulnerability is an unknown functionality of the file /student_edit1.php. Executing a manipulation of the argument ID can lead to sql injection. The attack can be launched remotely. The exploit has been made available to the public and could be used for attacks.
Affected Products	待核實
Risk Score	6.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-82424

CVE-2026-82417

CVE Title	CVE-2026-82417 待核實 Unknown Type
CVE Description	### Summary
Affected Products	待核實
Risk Score	5.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-82417



Report B: Threat Intelligence News (last 7 days)

Headline: How to secure edge AI in customer-owned environments

Source	Microsoft Security Blog
Published	Fri, 04 Sep 2026 19:10:10 +0000
Key Takeaway	As AI moves into customer-owned environments, organizations need new ways to verify the systems, software, and AI assets they trust before releasing sensitive data, credentials, and models. The post How to secure edge AI in customer-owned environments appeared first on Microsoft Security Blog . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	Credential Access
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/09/04/secure-edge-ai-customer-owned-environments/

Headline: ASCII smuggling crosses over from AI prompt injection to phishing evasion

Source	Microsoft Security Blog
Published	Thu, 03 Sep 2026 16:00:00 +0000
Key Takeaway	The post ASCII smuggling crosses over from AI prompt injection to phishing evasion appeared first on Microsoft Security Blog . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	Phishing
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/09/03/ascii-smuggling-crosses-over-from-ai-prompt-injection-to-phishing-evasion/

Headline: CISA Advisory Highlights Red Team Findings to Help Organizations Assess Risk, Identify Threats and Enable Effective Incident Response

Source CISA News

Published Tue, 25 Aug 26 12:00:00 +0000

Key Takeaway CISA Advisory Highlights Red Team Findings to Help Organizations Assess Risk, Identify Threats and Enable Effective Incident Response
Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.cisa.gov/news-events/news/cisa-advisory-highlights-red-team-findings-help-organizations-assess-risk-identify-threats-and>

Headline: CISA Releases Foundational, Flexible Guidance to Help Federal Agencies Implement Effective Logging, Visibility and Operational Standards

Source	CISA News
Published	Thu, 20 Aug 26 12:00:00 +0000
Key Takeaway	CISA Releases Foundational, Flexible Guidance to Help Federal Agencies Implement Effective Logging, Visibility and Operational Standards Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-releases-foundational-flexible-guidance-help-federal-agencies-implement-effective-logging

Headline: The story behind the intelligence

Source	Cisco Talos Blog
Published	Thu, 03 Sep 2026 18:00:13 GMT
Key Takeaway	From engaging with cybercriminals to surviving a live Flamin' Hot Cheetos taste test, Hazel reflects on the latest Beers with Talos with Azim, where they cover the full spectrum of what it takes to gather threat intel. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/the-story-behind-the-intelligence/

Headline: "Sorry, I can't help with that": How your guardrails might become the attacker's best friend

Source Cisco Talos Blog

Published Thu, 27 Aug 2026 18:00:24 GMT

Key Takeaway In his first Threat Source newsletter, David Bianco explores the critical need for operational sovereignty in customizing AI guardrails to maintain the defender's advantage. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://blog.talosintelligence.com/sorry-i-cant-help-with-that-how-your-guardrails-might-become-the-attackers-best-friend/>

Headline: Unpatched Magento and Adobe Commerce Zero-Day Exploited to Backdoor Online Stores	
Source	The Hacker News
Published	Sun, 06 Sep 2026 01:44:47 +0530
Key Takeaway	Attackers are exploiting a new unpatched vulnerability in Magento Open Source and Adobe Commerce that lets them run malicious code on an online store's server without logging in, Dutch e-commerce security company Sansec said in an advisory published on September 5. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/09/unpatched-magento-and-adobe-commerce.html

Headline: Attackers Breached JetBrains Cadence via Unpatched TeamCity, Extracting AWS Credentials

Source	The Hacker News
Published	Sat, 05 Sep 2026 22:22:33 +0530
Key Takeaway	JetBrains is urging Cadence users to revoke and rotate all credentials following a security incident last month in which unidentified threat actors exploited a recently disclosed critical vulnerability in TeamCity to breach its own environment. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/09/attackers-breached-jetbrains-cadence.html

Headline: Elementor Pro WordPress Plugin Vulnerability Exploited to Hack Sites

Source	SecurityWeek
Published	Sat, 05 Sep 2026 13:00:28 +0000
Key Takeaway	Tracked as CVE-2026-32475 (CVSS score of 9.8), the bug described as an arbitrary file upload issue in the function that handles form submissions. The post Elementor Pro WordPress Plugin Vulnerability Exploited to Hack Sites appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	CVE-2026-32475
Link	https://www.securityweek.com/elementor-pro-wordpress-plugin-vulnerability-exploited-to-hack-sites/

Headline: In Other News: Microsoft's Cloud Patches, Hacked Dropbox Accounts, Guardio's \$1.1B Valuation

Source	SecurityWeek
Published	Fri, 04 Sep 2026 16:18:30 +0000
Key Takeaway	Noteworthy stories that might have slipped under the radar: Microsoft rolled out patches for cloud services, hackers compromised 5,000 Dropbox accounts, and Guardio is now valued at \$1.1 billion. The post In Other News: Microsoft's Cloud Patches, Hacked Dropbox Accounts, Guardio's \$1.1B Valuation ap Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	cloud/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/in-other-news-microsofts-cloud-patches-hacked-dropbox-accounts-guardios-1-1b-valuation/

Headline: Over 5,400 hacked sites serve ClickFix payloads stored on the blockchain

Source BleepingComputer

Published Sat, 05 Sep 2026 10:29:13 -0400

Key Takeaway A massive cybercriminal operation is leveraging thousands of compromised small-business websites to deliver ClickFix payloads stored in smart contracts on the BNB Smart Chain (BSC). [...] Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.bleepingcomputer.com/news/security/over-5-400-hacked-sites-serve-clickfix-payloads-stored-on-the-blockchain/>

Headline: OpenAI admits it didn't disclose rogue AI wiki hijacking incident

Source BleepingComputer

Published Sat, 05 Sep 2026 07:11:50 -0400

Key Takeaway OpenAI admits it did not disclose an incident where autonomous AI agents hijacked a German wiki, created 18,000 posts, shared answers, and bypassed restrictions, saying it treated the activity as model "misalignment" rather than a security breach. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target ot/待核實

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://www.bleepingcomputer.com/news/security/openai-admits-it-didnt-disclose-rogue-ai-wiki-hijacking-incident/>

Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

<https://attack.mitre.org/>

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)